

# CVEs más relevantes de la semana

Del 23/06/2026 al 30/06/2026

Porque el primer paso para defender es conocer las amenazas.



## CVE-2026-44726

Descripción: Deno is a JavaScript, TypeScript, and WebAssembly runtime. From 2.0.0 until 2.7.8, a flaw in Deno's Node.js tls compatibility layer could cause a TLS client to transmit application data in plaintext after a connection retry. When `autoSelectFamily` was enabled and the first address-family attempt failed, the socket reinitialization path reused a stale TLS upgrade hook that was bound to the origi...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-319

Tecnología: No especificado

Publicado el: 2026-06-23



## CVE-2026-54316

Descripción: Claude Code is an agentic coding tool. From 0.2.54 until 2.1.163, because the hostname huggingface.co was pre-approved as a bare hostname for the WebFetch tool, any path on that domain—including attacker-controlled model repositories—was auto-approved without a permission prompt or being subject to --allowedTools restrictions. An attacker able to inject untrusted content into a Claude Code con...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-183

Tecnología: No especificado

Publicado el: 2026-06-23



## CVE-2026-53753

Descripción: Crawl4AI is an open-source LLM friendly web crawler & scraper. Prior to 0.8.7, the `_safe_eval_expression()` function in the computed fields feature uses an AST validator that only blocks attributes starting with underscore. Python generator and frame object attributes (`gi_frame`, `f_back`, `f_builtins`) do NOT start with underscore, enabling a complete sandbox escape to achieve arbitrary code executi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-06-23



## CVE-2026-48020

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to 2.11.48, 3.6.19, and 3.7.3, there is a high severity vulnerability in Traefik's StripPrefix middleware that allows an unauthenticated attacker to bypass route-level authentication and authorization. When a public router matches on a PathPrefix rule and applies the StripPrefix middleware, a request path containing .. or its percent-enc...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-23





## CVE-2026-48491

Descripción: Traefik is an HTTP reverse proxy and load balancer. From 3.7.0 until 3.7.3, there is a high severity vulnerability in Traefik's domain-fronting protection (SNICheck) that allows an unauthenticated client to bypass mutual TLS enforced through wildcard router TLSOptions. When a router uses a wildcard host rule such as Host(\*.example.com) with stricter TLS options (for example RequireAndVerifyClie...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-23



## CVE-2026-53622

Descripción: Traefik is an HTTP reverse proxy and load balancer. Prior to 3.7.3, there is a critical vulnerability in Traefik's HTTP/3 (QUIC) TLS configuration selection that allows unauthenticated clients to bypass router-specific mTLS enforcement. When HTTP/3 is enabled on an entrypoint, the TLS handshake selects the applicable TLS configuration through an exact, case-sensitive lookup on the SNI value, wh...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-23



## CVE-2026-56351

Descripción: n8n before version 2.4.0 contains a sql injection vulnerability in MySQL, PostgreSQL, and Microsoft SQL nodes that allows authenticated users to inject arbitrary SQL through unescaped identifier values in node configuration parameters. Attackers with workflow creation permissions can supply specially crafted table or column names to execute unauthorized database commands and compromise data integrity.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-24





## CVE-2026-56121

Descripción: Feast before 0.63.0 contains an unsafe deserialization vulnerability that allows unauthenticated or unauthorized attackers to achieve remote code execution by sending a crafted gRPC request to the registry server. The `user_defined_function.body` field of an `OnDemandFeatureView` spec is decoded from base64 and passed to `dill.loads()` before any authorization check is performed, enabling attackers t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-06-24



## CVE-2026-54906

Descripción: concurrent-ruby is a modern concurrency tools for Ruby. Prior to 1.3.7, Concurrent::ReadWriteLock#release\_write\_lock does not verify that the calling thread acquired the write lock. Any thread with access to the lock object can release an active write lock held by another thread. A second writer can then enter its critical section while the first writer is still running.

Concurrent::ReadWriteLo...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-414

Tecnología: No especificado

Publicado el: 2026-06-24



## CVE-2026-55455

Descripción: Appsmith is a platform to build admin panels, internal tools, and dashboards. Prior to 2.1, the outbound HTTP host filter applied by WebClientUtils (used by the REST API and GraphQL datasource plugins) validates hosts against an exact-match string denylist. The comprehensive address-class check (loopback, any-local, link-local, fc00::/7) exists only on a separate code path used by SMTP, not by ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-24



## CVE-2026-39948

Descripción: Cacti is an open source performance and fault management framework. In versions 1.2.30 and prior, the rfilter request parameter is retrieved via the raw accessor grv() (rather than gfrv() with FILTER\_VALIDATE\_IS\_REGEX validation) and concatenated directly into RLIKE SQL clauses in lib/html\_graph.php and lib/html\_tree.php, which are reachable pre-authentication through graph\_view.php on installa...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-24



## CVE-2026-40079

Descripción: Cacti is an open source performance and fault management framework. Versions 1.2.30 and prior are vulnerable to Command Injection due to lack of sanitization in the `escape_command()` function. The `escape_command()` function at `lib/rrd.php` is a no-op: it returns `$command` unchanged. The command line built by `rrdtool_function_graph()` is passed through this function and then to `shell_exec($full_comma...`

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25





## CVE-2026-8592

Descripción: OS Command Injection vulnerability in the process\_string action of Rapid7 InsightConnect AWK Plugin on Linux allows remote attackers to execute arbitrary OS commands via the text or expression parameters due to unsafe shell command construction in the processing pipeline.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-8660

Descripción: OS Command Injection vulnerability in the ping action of Rapid7 InsightConnect Ping Plugin on Linux allows remote attackers to execute arbitrary OS commands via the host parameter due to insufficient input validation when constructing shell commands.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-8665

Descripción: OS Command Injection vulnerability in the TR action of Rapid7 InsightConnect Translate Plugin on Linux allows remote attackers to execute arbitrary OS commands via the text or expression parameters due to insufficient input sanitization in shell command construction.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25





## CVE-2026-8666

Descripción: OS Command Injection vulnerability in the traceroute action of Rapid7 InsightConnect Traceroute Plugin on Linux allows remote attackers to execute arbitrary OS commands via the host, port, max\_ttl, count, or time\_out request parameters due to insufficient input validation when constructing shell commands.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-54030

Descripción: LibreChat is an enhanced ChatGPT clone that supports multiple AI providers. Prior to 0.8.5, LibreChat's MCP OAuth implementation does not validate that the resource parameter from OAuth Protected Resource metadata (RFC 9728) matches the configured MCP server URL, allowing a malicious MCP server to steal access tokens intended for a legitimate server. This vulnerability is fixed in 0.8.5.

CVSS: 8.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-56123

Descripción: socat versions 1.8.0.0 through 1.8.1.1 contain a heap-based buffer overflow vulnerability that allows a malicious SOCKS5 proxy server to overwrite adjacent heap memory by exploiting a sign-extension flaw in the DOMAINNAME reply parser. During connection setup, the domain name length byte is read through a signed char field causing a negative bytes\_to\_read value that is implicitly converted to s...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-6094

Descripción: Heap buffer overread in wc\_PKCS7\_DecodeEnvelopedData when parsing crafted PKCS7 EnvelopedData. This could theoretically be triggered by attacker-supplied data delivered via S/MIME or CMS.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-50548

Descripción: Cursor is a code editor built for programming with AI. Prior to 3.0, Cursor runs agent terminal commands in a sandbox by default, and the sandbox grants write access to the command's working directory. A flaw was identified in how the agent could modify the `working_directory` parameter, which could cause the sandbox to include writable paths outside the intended workspace. A malicious agent coul...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-06-25





## CVE-2026-50549

Descripción: Cursor is a code editor built for programming with AI. Prior to 3.0, Cursor runs agent terminal commands in a sandbox by default. Before a Write, the agent canonicalizes the target path to confirm it stays inside the workspace, but when canonicalization fails it falls back to the original path and writes without approval. A malicious agent can create an in-workspace symlink that points outside ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-54917

Descripción: SeaweedFS is a distributed storage system for object storage (S3), file systems, and Iceberg tables. Prior to 4.30, the S3 API gateway and the Iceberg REST catalog gateway construct their routers with `mux.NewRouter().SkipClean(true)`. With path cleaning disabled, a `..` segment inside the URL survives routing, so a request such as `'GET /bucket-A/../evil-bucket/key'`, is matched as `bucket=bucket-A, ...`

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-56786

Descripción: RTKLIB through 2.4.3 contains an out-of-bounds write vulnerability in decode\_type1033 function that fails to clamp length counters to destination buffer size, allowing up to 191-byte overflow into fixed 64-byte descriptor fields. An attacker controlling an NTRIP or serial RTCM3 correction stream can craft a valid CRC-bearing type-1033 message to corrupt adjacent rtcm\_t object members, potential...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-06-25





## CVE-2026-7531

Descripción: Use-after-free in PQC hybrid key-share handling. This is an incomplete-fix follow-up to CVE-2026-5460 (released in 5.9.1): a malicious TLS 1.3 server sending a truncated PQC hybrid KeyShare can still trigger the error cleanup path to operate on freed memory.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-25



## CVE-2026-48930

Descripción: A flaw in Node.js TLS hostname handling can cause Embedded-nul hostnames can lead to silent authority rebinding due to c-string truncation in resolver bindings. This vulnerability affects all supported release lines: **\*\*Node.js 22\*\***, **\*\*Node.js 24\*\***, and **\*\*Node.js 26\*\***.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-06-26



## CVE-2026-2053

Descripción: The WSO2 API Manager's message flow component, when processing WS-Addressing headers, does not sufficiently validate or restrict user-controlled input within these headers. This omission allows an attacker to manipulate WS-Addressing headers to specify arbitrary destinations for server-initiated requests.

Successful exploitation allows an unauthenticated attacker to control the destination of ...

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-26



## CVE-2026-53914

Descripción: In JetBrains Kotlin before 2.4.20 code execution was possible via unsafe deserialization in the build cache metadata

CVSS: 6.7 (MEDIUM)

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-06-26



## CVE-2026-57926

Descripción: In JetBrains YouTrack before 2026.2.16593 the websandbox bridge was vulnerable to a prototype pollution attack

CVSS: 2.6 (LOW)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:N

Tipo: CWE-1321

Tecnología: No especificado

Publicado el: 2026-06-26





## CVE-2026-54636

Descripción: Dokku is a docker-powered PaaS. Prior to 0.38.7, the cron plugin utilizes commands in the app.json file to manage system cron running as the Dokku user. An app.json cron command utilizing special shell characters - including, but not limited to, > or ; - can break out of the Docker container and execute commands on the host as the Dokku user. This vulnerability is fixed in 0.38.7.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-26



# CVE-2026-13751

Descripción: Improper handling of untrusted remote references in Snowflake CLI versions prior to 3.19 allowed server-side request forgery. The SQL statement reader's !source/!load directives could reference remote URLs that were retrieved at runtime without sufficient restriction on the request destination. By supplying crafted SQL content processed through a vulnerable command path, an attacker could cause...

CVSS: 4.1 (MEDIUM)

Vector: CVSS:3.1/AV:L/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:N

Tipo: CWE-829

Tecnología: No especificado

Publicado el: 2026-06-29



## CVE-2026-48276

Descripción: ColdFusion versions 2025.9, 2023.20 and earlier are affected by an Unrestricted Upload of File with Dangerous Type vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-06-30





## CVE-2026-48277

Descripción: ColdFusion versions 2025.9, 2023.20 and earlier are affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



## CVE-2026-48286

Descripción: Adobe Campaign Classic (ACC) versions 7.4.3 build 9396 and earlier are affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-06-30



## CVE-2026-58166

Descripción: OpenBMB ChatDev through 2.2.0, fixed in commit 4fd4da6, contains a path traversal vulnerability that allows unauthenticated remote attackers to write or delete arbitrary files by supplying a malicious multipart filename in the file upload endpoint. Attackers can send a crafted filename containing path traversal sequences or an absolute path to the POST uploads session endpoint, which constructs...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-06-30



## CVE-2026-58172

Descripción: Ocelot through 24.1.0, fixed in commit f156fd4, contains a security control bypass vulnerability that allows denied clients to circumvent IP-based access restrictions by sending WebSocket upgrade requests. The WebSocket upgrade pipeline branch configured via MapWhen in OcelotPipelineExtensions.cs omits SecurityMiddleware, causing requests from blocked IP addresses to be proxied to downstream se...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-06-30



## Resumen del Reporte

CVEs analizados: 35

Promedio CVSS: 8.76

Fuente: [nvd.nist.gov](https://nvd.nist.gov)

Nos vemos la próxima semana. Hack the Cat ☹

